

gh_zipcode — 台灣 3+3 郵遞區號查詢

靜態前端部署於 GitHub Pages，資料與 API 由 Supabase 提供；含免 key 的公開查詢 API 與需審核的使用者留言板。

一、專案概觀

本專案把中華郵政 3+3 郵遞區號資料放進 Supabase

Postgres，前端是純靜態頁面，沒有自架後端伺服器。查詢有兩條路徑：網頁直接以 anon key 呼叫資料庫

RPC，或外部程式呼叫免 key 的 Edge Function。留言板走同一組

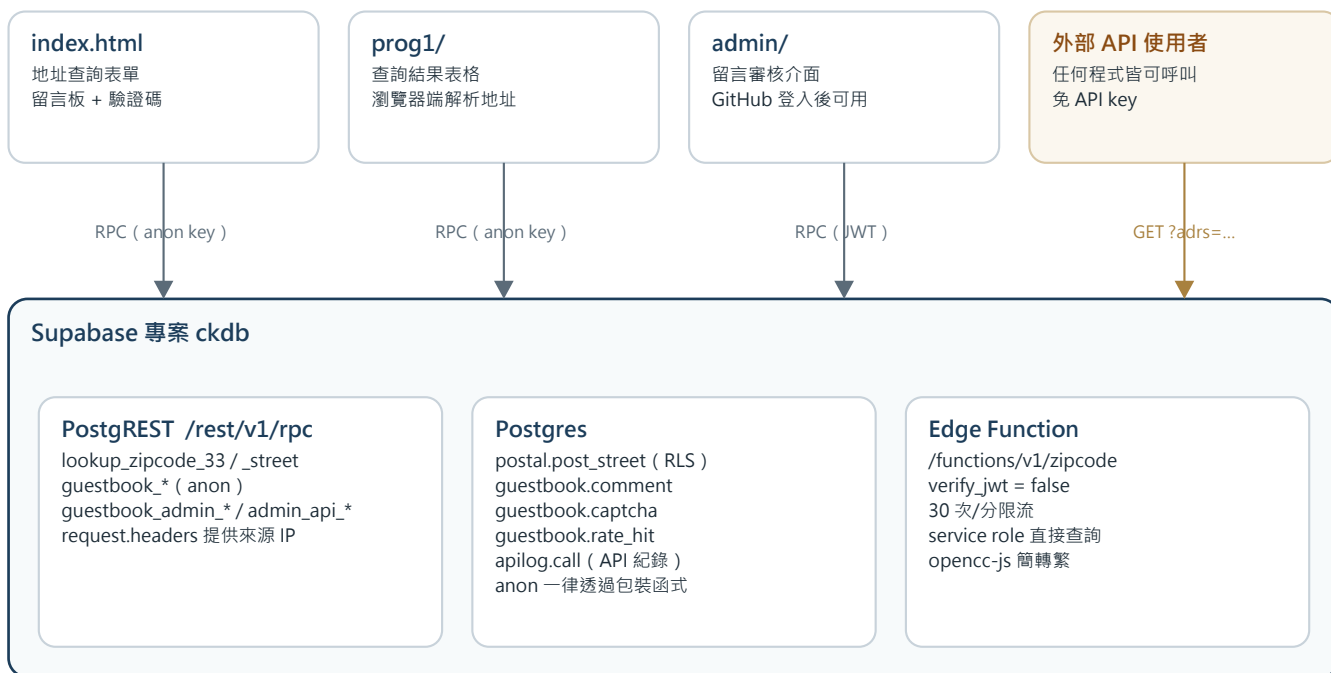
RPC，但寫入前必須通過伺服器端產生的圖形驗證碼，且預設不公開、需站長審核。

組成	內容	說明
前端	index.html、prog1/、admin/	純靜態；GitHub Actions 自動部署至 Pages
資料	postal.post_street	RLS 開啟並撤銷 anon；只透過 public 包裝函式讀取
留言	guestbook.comment / captcha / rate_hit	同樣鎖在自有 schema，anon 全撤銷
API	Edge Function zipcode	免 API key 的公開 GET 介面，verify_jwt = false
身分	GitHub OAuth (Supabase Auth)	僅供 admin/ 審核頁使用

二、系統架構

用戶端

GitHub OAuth → auth.identities.provider_id 比對 11531735



四個用戶端都只透過 Supabase 對外的介面存取資料：網頁用 anon key 呼叫 PostgREST 上的 RPC，審核頁改帶登入後的 JWT，外部程式則走 Edge Function。原始資料表本身對 anon 完全關閉。

三、安裝步驟

以下步驟從零建立一份可運作的環境。需要 Supabase 專案、GitHub 帳號，以及匯出郵遞區號原始資料用的 Windows PowerShell。

1. 建立資料庫結構

在 Supabase SQL Editor 依檔名順序執行 `supabase/migrations/` 內全部 SQL：0001–0006 建立郵遞區號結構與查詢函式，0007–0011 建立留言板、審核權限、限流、長度上限與 API 呼叫紀錄。每一份都可重複執行。

2. 匯入郵遞區號資料

```
.\tools\export-post-street.ps1 -ConnectionString '<mssql connection string>'
```

接著在 Supabase Table Editor 選擇 `postal.post_street` → Import data from CSV，匯入產生的 `out/post_street.csv`。

3. 設定前端連線

複製 `assets/js/config.example.js` 為 `assets/js/config.js`，填入專案 URL 與 anon key：

```
window.POSTAL_CONFIG = {
  supabaseUrl: "https://<project>.supabase.co",
  supabaseAnonKey: "<anon key>"
};
```

anon key 設計上就是公開的，隨 GitHub Pages 一起發佈沒有問題；service role key 與 OAuth client secret 絕對不可放進這個檔案或 repo。

4. 部署 Edge Function

```
supabase functions deploy zipcode
```

`supabase/config.toml` 已設定 `verify_jwt = false`，讓它成為免 key 的公開 API。請優先使用 CLI 部署；直接在 Dashboard 編輯器改程式碼容易與 git 版本產生分歧。

5. 發佈網站

推送到 main 分支即可，`.github/workflows/deploy-pages.yml` 會自動部署到 GitHub Pages。

四、資料定期更新

```
.\tools\export-post-street.ps1 -ConnectionString '<mssql connection string>'
.\tools\new-post-street-update.ps1
```

第二個指令會在 `out\update` 產生每批 1,000 筆的 upsert SQL 與驗證 SQL，依檔名順序貼進 SQL Editor 執行即可。

五、檔案結構

路徑	用途
<code>index.html</code>	查詢表單與使用者留言板
<code>prog1/index.html</code>	查詢結果頁
<code>admin/index.html</code>	留言審核頁（需 GitHub 登入）
<code>assets/js/address.js</code>	地址解析，與 Edge Function 同一套規則
<code>assets/js/supabase-client.js</code>	RPC 呼叫封裝
<code>assets/js/guestbook.js</code> 、 <code>admin.js</code>	留言板與審核頁前端
<code>assets/js/config.js</code>	專案 URL 與 anon key，不含任何機密
<code>supabase/functions/zipcode/</code>	公開 API 的 Edge Function
<code>supabase/migrations/</code>	資料庫結構與函式
<code>tools/</code>	郵遞區號資料匯出與更新腳本
<code>sitemap.xml</code> 、 <code>assets/favicon.svg</code>	搜尋引擎與瀏覽器用的靜態資源
<code>docs/</code>	本說明文件

六、審核介面設定 (GitHub 登入)

admin/ 只有指定的 GitHub 帳號看得到留言資料。啟用需要三個步驟，其中 client secret 只能填在 Supabase，不可寫入 repo。

步驟	位置	內容
1	GitHub → Developer settings → OAuth Apps	新增應用程式。Homepage 填站台網址；Authorization callback URL 填 <code>https://<project>.supabase.co/auth/v1/callback</code> 。建議關閉 Allow wildcard matching。
2	Supabase → Authentication → Providers → GitHub	開啟並填入 Client ID 與 Client Secret。瀏覽器自動填入可能塞進錯誤內容，填寫前先清空欄位。
3	Supabase → Authentication → URL Configuration	Site URL 設為站台網址；Redirect URLs 加入 <code><站台網址>/admin/</code> 。

權限判斷方式

```
select exists (select 1 from auth.identities i
  where i.user_id = auth.uid() and i.provider = 'github'
    and i.provider_id = '11531735');
```

比對的是 `auth.identities.provider_id` (GitHub 數字 ID)，不是 JWT 內的 `user_metadata.user_name` — 後者使用者可自行改寫，拿來把關等於沒有把關。數字 ID 也不受改名影響。要換帳號請修改 0008 內的數字後重跑。

七、留言審核流程

留言寫入時 `is_approved = false`，不會出現在公開頁面。登入 admin/ 後可核准、取消核准或刪除；亦可直接在 SQL Editor 操作：

```
update guestbook.comment set is_approved = true where id = <id>;
```

八、API 呼叫紀錄

公開 API 每次被呼叫都會寫入 `apilog.call`：時間、來源 IP、查詢地址、HTTP 狀態、命中筆數與耗時；被限流或被拒絕的請求同樣會記錄，因為那些才是最值得看的。寫入只授權給 `service_role`，外部無法用 anon key 偽造紀錄；讀取透過 `admin_api_log` 與 `admin_api_stats`，一樣由 `is_admin()` 把關，並顯示在 admin/ 頁面上。

來源 IP 屬個人資料，保留 30 天後清除。清理搭在寫入路徑上、以約 1% 的機率觸發，因此 30 天是概略值而非保證；若需要準時清除，可改用 `pg_cron` 排程。

九、防濫用與安全

項目	設定	說明
驗證碼	5 位數字 (2-9)	以 path 筆畫繪製而非文字節點，答案不會出現在 SVG 原始碼裡
驗證碼次數	每組只能試一次	答錯即失效，避免對同一張圖窮舉
發驗證碼	20 次 / 分 / IP	超過回傳 400 與提示訊息
送出留言	10 次 / 分 / IP	先計次再驗證，失敗嘗試同樣計入
公開 API	30 次 / 分 / 來源	由 Edge Function 自行實作
長度上限	暱稱 10 字、留言 100 字	以 <code>length()</code> 計字元數，伺服器端為準

已知限制

- admin/ 的 HTML 與 JS 是公開靜態檔，任何人都能下載原始碼；受保護的是留言資料與核准 / 刪除動作，由資料庫端強制，不是靠隱藏頁面。
- 限流以來源 IP 計算。若 `x-forwarded-for` 取不到，`client_key()` 會回傳 `unknown`，所有人共用一個桶而被一起限流 (刻意不 fail-open)。
- `guestbook_list_comments` 不限流：只讀已公開的資料，也不產生任何列。